

Báo cáo Lỗi, Khuyết tật & Bảo mật Ứng dụng (Full Bug & Vulnerability Report)

- Sinh viên:** Mai Thị Kim Duyên
- MSSV:** 23127185
- Hệ thống kiểm thử:** Backend EShop SUT (`http://localhost:3000`)
- Nguồn dữ liệu phân tích:** Quá trình thực thi JMeter 90 mẫu, Log thô JTL (`jmeter/results/`), HTML Report (`jmeter/reports/`) và Rà soát mã nguồn Backend (`eshop-sut/backend/server.js`).

Phần 1: Phân tích Vấn đề Hiệu năng từ Kết quả JTL & HTML Report

Dựa trên phân tích 90 mẫu từ file JTL thô và file `statistics.json` của báo cáo HTML:

Sampler / Transaction	Load Avg (ms)	Load P95 (ms)	Stress Avg (ms)	Spike Avg (ms)	Nhận xét điểm nghẽn (Bottleneck)	GitHub Issue
Register	41.50	51.45	8.60	12.10	Nghẽn đĩa Ghi (Write-heavy): Độ trễ cao nhất hệ thống. Do SQLite thực hiện ghi đĩa <code>INSERT INTO users</code> đồng bộ.	#12
Checkout	34.70	54.70	2.90	3.40	Nghẽn đĩa Ghi (Write-heavy): Độ trễ cao thứ 2. Do thao tác <code>INSERT INTO orders</code> đồng bộ.	#12
Login	1.70	2.00	1.50	1.50	Đáp ứng nhanh (xác thực JWT & query <code>SELECT</code>).	-
Categories	0.90	1.90	0.80	0.80	Rất nhanh (Read-heavy, query danh mục).	-
ProductList	0.70	1.00	0.70	0.90	Rất nhanh (Read-heavy, query tìm kiếm).	-
ProductDetail	1.10	2.00	0.90	0.60	Rất nhanh (Read-heavy, query chi tiết).	-
AddToCart	0.90	1.00	0.90	1.00	Rất nhanh (Lưu giỏ hàng trên RAM/In-memory).	-
ApplyCoupon	1.30	2.00	0.90	1.20	Nhanh, nhưng thiếu kiểm tra xác thực.	#15
Orders	1.30	2.00	0.80	1.10	Nhanh (Read-heavy, lấy lịch sử đơn).	-

Phần 2: Danh sách Toàn bộ 11 Bug, Khuyết tật Logic & Lỗi hỏng Bảo mật trong SUT

Qua rà soát chuyên sâu source code `eshop-sut/backend/server.js` , tìm thấy tổng cộng **11 lỗi & lỗ hổng bảo mật**:

STT	Loại Bug	Tên Bug / Lỗ hỏng	Vị trí Source Code	Hành vi Kỳ vọng	Hành vi Thực tế trong Code
1	Performance	Nghẽn I/O đĩa synchronous SQLite	<code>database.js</code> & <code>server.js</code>	Ghi dữ liệu bất đồng bộ không làm nghẽn thread.	INSERT đồng bộ làm latency Register và Checkout cao gấp 40 lần Read.
2	Security	Lỗ hỏng SQL Injection	<code>server.js</code> (dòng 143-151)	Phải dùng parameterized query (?).	Nối chuỗi trực tiếp: <code>LIKE '%\${searchQuery}%'</code> . Dễ bị tấn công SQLi.
3	Security	Lỗ hỏng Leo thang đặc quyền (Privilege Escalation)	<code>server.js</code> (dòng 118-128)	User thường không được tự sửa role.	<code>PUT /api/users/me</code> cho phép truyền <code>{ "role": "admin" }</code> để tự thăng cấp Admin.
4	Security	Tin tưởng <code>total_amount</code> từ Client (Price Tampering)	<code>server.js</code> (dòng 297)	Backend phải tự tính lại tiền từ DB.	Nhận trực tiếp <code>total_amount</code> từ Client trong <code>req.body</code> . Hacker sửa giá 0 đ.
5	Security	Thiếu Middleware xác thực API Coupon	<code>server.js</code> (dòng 363)	Phải đăng nhập (<code>authenticateToken</code>) mới được áp mã.	Route <code>POST /api/apply-coupon</code> công khai không có middleware xác thực token.
6	Logic	Bộ đếm lần đăng nhập sai & thời gian khóa bị lặp	<code>server.js</code> (dòng 54-58)	Tăng 1 lần thử; khóa 30s sau 3 lần sai.	Code tăng +2 (<code>login_attempts + 2</code>) và khóa 180s. Gỡ sai 2 lần bị khóa 3 phút.
7	Logic	Công thức tính giảm giá phần trăm bị sai	<code>server.js</code> (dòng 400 & 420)	Giảm $X\% = total * (X / 100)$.	Code tính <code>total * (1 - discount_value)</code> . Giảm 10% tính thành giảm 90%.
8	Logic	So sánh ngưỡng tối thiểu	<code>server.js</code> (dòng 379)	Đơn hàng đạt từ mức tối thiểu ($\geq min$).	Dùng dấu <code>></code> (<code>total_amount > min_order_amount</code>).

		Coupon sai bất đẳng thức			Đơn bằng đúng giá min bị từ chối.
9	Logic	Cho phép chuyển trạng thái đơn hàng Canceled -> Delivered	server.js (dòng 551)	Đơn bị hủy (canceled) không được chuyển sang delivered.	Code ghi: if (currentStatus === "canceled" && status === "delivered") isValidTransition = true;.
10	Functional	Cho phép Hủy đơn hàng đang trong trạng thái Shipping	server.js (dòng 328-331)	Chỉ cho hủy đơn pending hoặc confirmed.	Khối if bỏ quên trạng thái shipping, cho phép user hủy đơn khi hàng đang giao.
11	Functional	Bất đồng nhất kiểu dữ liệu Giá sản phẩm (Data Type Mismatch)	server.js (dòng 162-164)	Giá sản phẩm luôn là kiểu Number.	Code ép kiểu if (row.id % 2 === 0) row.price = row.price.toString(). ID chẵn trả String, lẻ trả Number.

Phụ lục: Khuyến dùng Tối ưu & Remediation

- Khắc phục SQL Injection:** Dùng Parameterized Query: `db.all("SELECT * FROM products WHERE name LIKE ?", ['%' + searchQuery + '%'])`.
- Khắc phục Leo thang đặc quyền:** Loại bỏ trường `role` khỏi phần xử lý `PUT /api/users/me`.
- Tối ưu Hiệu năng SQLite:** Bật chế độ Write-Ahead Logging `PRAGMA journal_mode = WAL;`.
- Sửa Logic Đăng nhập & Mã giảm giá:** Đổi `attempts + 1`, thời gian khóa `30000ms`, sửa công thức coupon `total * (value / 100)` và điều kiện `>=`.
- Khắc phục Chuyển trạng thái Đơn hàng:** Sửa máy trạng thái trong `server.js` không cho phép chuyển từ `canceled` sang `delivered` hoặc `shipping`.